

Livrable 1 (TD02) : Rapport de Gestion de Projet

Déploiement d'une Infrastructure de Cybersécurité Open Source pour PME (Projet OSSI)

Équipe Projet :

Kevin Ojoduma-Quéré
Guillaume Ortells
Antoine Poirier
Emmanuel Rajaonera
Mohamed Ouadihi

2026

Table des matières

1	Analyse du Cycle de Vie et Cadrage Initial du Projet OSSI	2
1.1	Introduction et Justification de la Démarche Projet	2
1.2	Présentation Synthétique du Projet OSSI	2
1.3	Analyse du Cycle de Vie du Projet	4
1.4	Le Principe de Fusée Appliqué au Projet OSSI	6
2	Structuration Séquentielle (Approche Waterfall)	8
2.1	Planification opérationnelle : Phases et Jalons décisionnels	8
3	Application et Modélisation Complète du Cycle en V	11
3.1	Côté Gauche du V : Phases de Conception	11
3.1.1	Spécifications Fonctionnelles	11
3.2	Base du V : Phase de Réalisation et Organisation Opérationnelle	14
3.3	Côté Droit du V : Stratégie de Tests et Validation	15
4	Gouvernance, Risques et Pilotage Qualité	19
4.1	Gouvernance du Projet OSSI	19
4.2	Répartition des Rôles et Responsabilités	20
4.3	Analyse et Registre des Risques	20
4.4	Critères de Validation des Livrables	21
4.5	Indicateurs de Suivi (KPIs)	22
5	Analyse Critique et Réflexion Managériale	23
5.1	Analyse Critique du Cycle en V dans le Contexte OSSI	23
5.2	Comparaison avec une Approche Agile ou Hybride	24
5.3	Conclusion Réflexive et Apports pour la Formation d'Ingénieur	25

Chapitre 1

Analyse du Cycle de Vie et Cadrage Initial du Projet OSSI

1.1 Introduction et Justification de la Démarche Projet

Les cyberattaques se multiplient et se sophistiquent. Les grandes structures se défendent ; les PME, financièrement et humainement vulnérables, sont devenues la cible privilégiée. Le projet OSSI (Open Source Security Infrastructure) répond à ce risque : déployer une architecture réseau périmétrique performante (pfSense, Suricata, VPN IPSec/WireGuard) entièrement Open Source, pour une résilience numérique accessible.

Nécessité d'une Approche Projet Structurée

L'intégration de briques critiques dans un système d'information n'autorise aucune improvisation, pour trois raisons :

- **Gestion des contraintes** : le budget et les délais du Mastercamp imposent un périmètre strictement formalisé.
- **Maîtrise de l'incertitude** : les risques techniques inhérents au réseau (routage, failles) s'anticipent par des scénarios de contingence.
- **Gouvernance** : la coordination équipe / client / encadrants exige des instances de décision claires.

Cette exigence de rigueur structurelle pose la question du cycle de vie à retenir pour piloter OSSI ; elle est développée en Section 1.3, où le choix méthodologique est justifié et confronté aux approches alternatives.

1.2 Présentation Synthétique du Projet OSSI

a) Contexte et Genèse du Besoin

Les cyberattaques visant les PME ont augmenté de 400% ces dernières années. Cette vulnérabilité est aggravée par une barrière économique : les solutions « *Enterprise Grade* » (Palo Alto, Cisco) restent inaccessibles à ces budgets en raison de leurs licences récurrentes prohibitives.

b) Problématique : La Démocratisation de la Cybersécurité

La problématique repose sur un paradoxe : *comment offrir aux PME une sécurité réseau de niveau entreprise sous contrainte budgétaire drastique ?* L'enjeu est de substituer aux solutions propriétaires une infrastructure *Open Source* performante, sans perte de protection, en déplaçant la valeur du coût de licence vers l'ingénierie système.

c) Objectifs Techniques et Opérationnels

OSSI propose une architecture périmétrique complète, en défense en profondeur :

- **Cœur de réseau** : pare-feu **pfSense** pour la segmentation et le filtrage granulaire.
- **Connectivité sécurisée** : tunnels **IPSec** et **WireGuard** pour des accès distants chiffrés.
- **Détection d'intrusions** : sonde **Suricata** en analyse IDS/IPS temps réel.
- **Visibilité et Analyse** : **ntopng** pour la métrologie et une instance **Ollama** (IA locale) convertissant les logs bruts en rapports décisionnels vulgarisés pour le dirigeant.

Le déploiement est calibré pour un budget cible de **6 875 €** (matériel et ingénierie de mise en service).

d) Gouvernance et Parties Prenantes

La réussite repose sur quatre entités :

1. **L'équipe projet** : cinq ingénieurs EFREI, garants de la conception, de l'implémentation et de la recette.
2. **La PME cliente (le dirigeant)** : porteur de la vision stratégique, bénéficiaire d'une solution pilotable sans technicité.

e) Analyse de la Valeur Ajoutée (ROI)

L'intérêt économique d'OSSI apparaît dans le coût total de possession (TCO) sur trois ans :

TABLE 1.1 – Comparatif du TCO sur 3 ans : Propriétaire vs OSSI

Indicateur	Solution Propriétaire	Solution OSSI
Coût initial (Hardware/Soft)	15 000 €	4 500 €
Licences	30 000 €	0 €
Maintenance (3 ans)	0 € (inclus)	3 500 €
TCO total sur 3 ans	> 45 000 €	8 000 €

Cette architecture réduit le TCO de plus de **80%**, transformant un centre de coûts en investissement pérenne. Au-delà des outils, OSSI constitue un levier de souveraineté numérique : la PME réalloue ses ressources vers son cœur de métier tout en atteignant un niveau de sécurité critique.

f) Matrice des Parties Prenantes

TABLE 1.2 – Matrice d’analyse des parties prenantes du projet OSSI

Partie Prenante	Rôle dans le Projet	Niveau d’Influence	Attentes Principales
Équipe Projet	Conception, réalisation et recette technique.	Élevé	Livraison conforme, respect des délais, montée en compétence.
Dirigeant PME	Client et décideur stratégique.	Élevé	Sécurité accrue, coût maîtrisé, simplicité de pilotage.
Comité de Pilotage	Supervision et validation académique.	Élevé	Rigueur méthodologique, respect du cadre pédagogique FG601.

1.3 Analyse du Cycle de Vie du Projet

Le management de projet n’est pas une simple exécution de tâches, mais un processus de transformation structuré faisant passer l’organisation d’un état de vulnérabilité à un état de résilience numérique. Pour OSSI, ce cycle de vie matérialise le passage d’une abstraction stratégique à une solution technique éprouvée et documentée.

a) La Dynamique de Réduction de l’Incertitude

À l’origine, OSSI est une idée à forte incertitude : quel matériel sera compatible ? Quelle topologie isolera les flux sans dégrader les performances ? Comment vulgariser les logs pour un dirigeant non-technicien ? Selon la théorie du cycle de vie, l’avancement réduit l’incertitude : chaque phase agit comme un filtre de complexité, transformant les inconnues en hypothèses validées puis en spécifications figées. Cette « cristallisation » est le socle de la maîtrise des risques et garantit la prédictibilité des résultats.

b) Le Concept de Jalons de Transition : "Portes Logiques"

Le projet repose sur des jalons de transition, « portes logiques » conditionnant la poursuite du cycle. Ces revues ne sont pas de simples points de suivi mais des ruptures où la validité des acquis est remise en question.

- **Jalon d’opportunité** : Validation du besoin client et de la viabilité économique (le passage sous la barre des 7 000 €).
- **Jalon de conception** : Validation de l’architecture logicielle (choix de pfSense/Suricata) et des interfaces système.
- **Jalon de recette** : Validation technique de la solution en environnement de pré-production.

Chaque porte franchie verrouille une partie du périmètre, empêchant toute dérive du *scope* et garantissant que les fondations (routage, sécurité périmétrique) sont saines avant l’ajout des couches applicatives (IA Ollama).

c) La Justification d’un Cycle de Vie Prédictif pour l’Infrastructure

Cette dynamique de réduction de l’incertitude appelle un cycle de vie prédictif plutôt qu’itératif. Là où l’agilité introduirait une flexibilité risquée pour une infrastructure réseau, le **Cycle**

en V s'impose pour trois raisons : la cybersécurité exige une architecture figée et validée, modélisée avant toute exécution matérielle (*prévisibilité*) ; les composants (pfSense, Suricata) présentent des dépendances fortes que seul le séquençement strict du V rend cohérentes (*dépendances techniques*) ; et sa branche montante établit une correspondance biunivoque entre exigences de sécurité et tests de recette, garantissant traçabilité et fiabilité (*rigueur de validation*). Le Tableau 1.3 objective cet écart en confrontant les conséquences d'une démarche structurée à celles d'une gestion empirique, telle qu'observée dans la majorité des PME non accompagnées.

TABLE 1.3 – Analyse comparative : Approche structurée OSSI vs Risques opérationnels en PME

Critère	Approche Structurée (OSSI)	Approche Non Structurée (PME)
Gestion des Coûts	Maîtrise budgétaire par le TCO et planification des ressources.	Dérives financières imprévues et surcoûts liés aux incidents.
Poste de Sécurité	Architecture robuste : pfSense, Suricata, VPN, chiffrés.	Failles critiques, absence de visibilité sur les flux réseau.
Pérennité	Reproductibilité et documentation technique exhaustive.	Dépendance à l'expertise tacite d'un seul individu (risque humain).
Stabilité	Déploiement basé sur des jalons de validation (Cycle en V).	Risque élevé de perte de données par configuration empirique.

Au-delà de cet arbitrage initial, une infrastructure réseau périmétrique exige une stabilité totale une fois la conception engagée : une modification « agile » de dernière minute sur une règle de pare-feu ou une configuration IPSec pourrait ouvrir une faille critique ou paralyser les communications du client. Le Cycle en V sécurise ainsi l'architecture par :

1. **La correspondance biunivoque** : à chaque exigence de sécurité (phase descendante) répond un test (phase montante). Cette symétrie est la garantie formelle d'une sécurité *by design*.
2. **La formalisation contractuelle** : le cahier des charges sert de référentiel de vérité, alignant attentes du dirigeant et capacité technique de l'équipe.
3. **La reproductibilité industrielle** : la documentation exhaustive (matrice de flux, schémas) transforme une solution artisanale en produit industriel, permettant une prise en main en autonomie après la clôture.

d) Modélisation de la réduction de l'incertitude

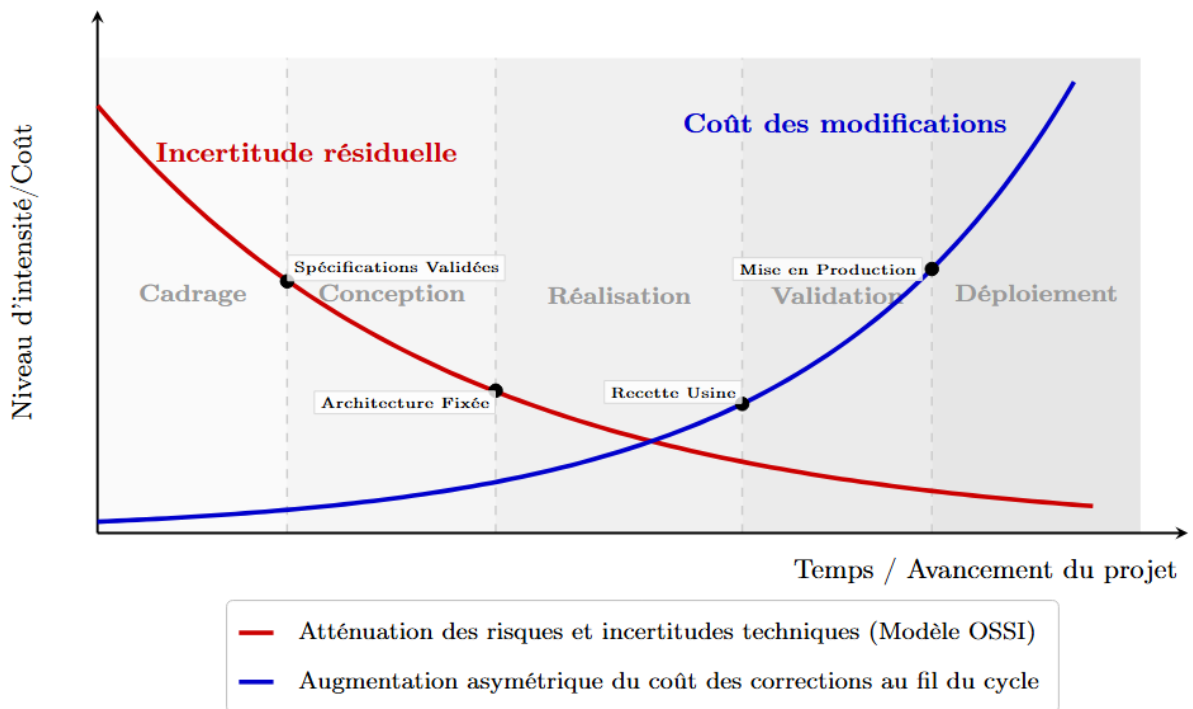


FIGURE 1.1 – Dynamique croisée entre la réduction de l'incertitude et l'effort financier des changements au sein du cycle de vie OSSl.

1.4 Le Principe de Fusée Appliqué au Projet OSSl

Le **Principe de Fusée** (module FG601) éclaire la trajectoire d'OSSI : tout projet doit se délester progressivement de ses étages les moins nobles (incertitude, ambiguïté, risque non maîtrisé) pour gagner en altitude, c'est-à-dire en structure et en valeur. Chaque étage franchi est irréversible, ce qui distingue un projet structuré d'une improvisation. Appliqué à OSSl, ce délestage progressif transforme un simple constat de vulnérabilité en un livrable certifié : l'*Idée* (la menace diffuse pesant sur les PME) est soumise au *Filtre* de la faisabilité technique et budgétaire, puis consolidée en *Avant-projet* chiffré, mis en œuvre comme *Projet* structuré sur huit séances, pour finalement livrer une infrastructure documentée et intelligible. Le Tableau 1.4 synthétise comment chaque étage réduit l'incertitude tout en augmentant la valeur et la structure, en miroir de la Figure 1.1.

TABLE 1.4 – Application du Principe de Fusée au projet OSSI

Étage	Contenu pour le projet OSSI	Risque éliminé / valeur gagnée
Idée	Constat de la vulnérabilité des PME (+400% d'attaques).	Aucune structure ; multiplicité des pistes envisageables.
Filtre	Comparatif Open Source vs propriétaire ; arbitrage du risque de compétence pfSense/Suricata.	Élimination des solutions hors budget ; risque de compétence identifié et provisionné.
Avant-projet	Périmètre fonctionnel (pfSense, VPN, Suricata, ntopng/Ollama) ; budget de 6 875 € ; matériel reconditionné à 850 €.	Faisabilité économique vérifiée ; jalon d'opportunité franchi.
Projet	Planification sur 8 séances ; choix du Cycle en V ; allocation des 5 ingénieurs.	Discipline calendaire ; spécifications figées avant réalisation.
Livrable	Infrastructure documentée + rapports Ollama vulgarisés pour le dirigeant.	Incertitude résiduelle minimale ; valeur maximale et appropriable par le client.

En définitive, à chaque étage largué (pistes écartées du Filtre, hypothèses non confirmées de l'Avant-projet), la fusée se déleste d'un poids mort qui l'aurait empêchée d'atteindre son orbite. Le livrable est ainsi la trace d'un processus rigoureux de sélection et de structuration, transformant un constat diffus en une infrastructure concrète, mesurable et durable.

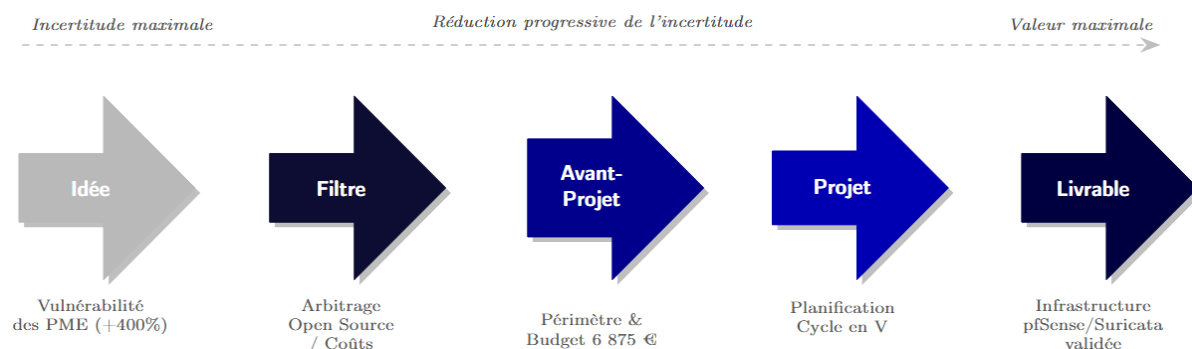


FIGURE 1.2 – Le Principe de Fusée appliqué au projet OSSI

Chapitre 2

Structuration Séquentielle (Approche Waterfall)

2.1 Planification opérationnelle : Phases et Jalons décisionnels

La structuration séquentielle d'OSSI repose sur un principe : la clôture irréversible de chaque phase, scellée par un jalon Go/No-Go du Comité de Pilotage (COPIL), conditionne l'ouverture de la suivante. Dans un projet réseau, toute ambiguïté non résolue en amont devient en réalisation une faille exploitable ou une incompatibilité bloquante. Le Comité de Pilotage arbitre chaque jalon par une décision **Go**, **Go conditionnel** ou **No-Go**, consignée dans un procès-verbal signé. Le découpage retenu articule six étapes, détaillées ci-après.

Étape 1 — Étude d'Opportunité et Faisabilité (J1)

Cette phase répond à la question : *le projet mérite-t-il d'être lancé ?* Elle quantifie la menace pesant sur les PME, évalue la viabilité de la substitution *Open Source* (cf. Tableau 1.1) et confirme la disponibilité des ressources avant tout engagement budgétaire.

- **Objectif du Jalon** : confirmer la pertinence stratégique et économique du projet et valider le périmètre technologique.
- **Livrable exigé** : rapport de faisabilité (analyse TCO, cartographie des parties prenantes, matrice des risques initiaux).
- **Critères d'acceptation techniques** : TCO sur trois ans inférieur à 7 000 € ; maturité communautaire des trois briques (pfSense, Suricata, WireGuard) attestée.
- **Rôle de garde-fou** : empêche le lancement d'un projet non viable et verrouille la liste des technologies, première barrière contre le *scope creep* technologique.

Étape 2 — Cadrage et Spécifications Fonctionnelles (J2)

La phase de cadrage transforme les besoins métier en exigences formalisées et produit le cahier des charges fonctionnel délimitant le périmètre : flux à filtrer, niveaux de journalisation, plages horaires d'accès VPN, format des rapports Ollama. Rouvrir ces spécifications après le lancement de la conception engendrerait des reprises en cascade incompatibles avec le budget de 6 875 €.

- **Objectif du Jalon** : geler le référentiel fonctionnel ; toute exigence nouvelle exige désormais une décision formelle du COPIL.
- **Livrable exigé** : cahier des charges fonctionnel (CCF) signé.
- **Critères d'acceptation techniques** : couverture à 100% des besoins exprimés ; chaque exigence formulée en MoSCoW et associée à un critère de test mesurable.
- **Rôle de garde-fou** : verrou principal contre le *scope creep* fonctionnel ; toute demande post-jalon déclenche une procédure de gestion des changements.

Étape 3 — Conception Détaillée de l'Architecture Réseau (J3)

Sur la base des spécifications gelées, cette phase produit les artefacts techniques : plan d'adressage IP, matrice de flux et politiques pfSense, schémas logiques et physiques, paramètres des tunnels IPsec/WireGuard et signatures Suricata par défaut. La solution est vérifiée sur le papier avant toute manipulation matérielle.

- **Objectif du Jalon** : valider la cohérence et la complétude de l'architecture avant la phase de réalisation.
- **Livrable exigé** : dossier d'architecture complet (adressage, matrice de flux, paramètres VPN, schémas).
- **Critères d'acceptation techniques** : aucune contradiction adressage/filtrage ; traçabilité biunivoque règle pfSense $\leftrightarrow$ exigence CCF ; algorithmes conformes aux recommandations ANSSI (IKEv2, AES-256, ChaCha20).
- **Rôle de garde-fou** : verrouille l'architecture ; toute modification post-validation déclenche un *change request* en cascade.

Étape 4 — Réalisation et Configuration des Maquettes (J4)

Base du Cycle en V, cette phase matérialise les schémas en configurations sur le matériel reconditionné : installation et durcissement de pfSense, déploiement de Suricata, mise en service des tunnels VPN, intégration de ntopng et Ollama. Toute dérive par rapport aux schémas validés fait l'objet d'une demande de changement validée par le COPIL.

- **Objectif du Jalon** : vérifier la conformité de la maquette à l'architecture J3 et le fonctionnement isolé de chaque composant avant intégration.
- **Livrable exigé** : maquette opérationnelle complète, rapport de configuration et journal de déploiement.
- **Critères d'acceptation techniques** : adressage implémenté conforme à 100% à J3 ; démarrage nominal de tous les services ; premier test de connectivité VPN réussi.
- **Rôle de garde-fou** : interdit le passage aux tests sur une maquette instable ou partielle, qui invaliderait les résultats des tests de pénétration.

Étape 5 — Validation et Tests de Pénétration/Charge (J5)

Pour une infrastructure de cybersécurité, la validation dépasse le contrôle fonctionnel : tests de pénétration (DoS simulé, contournement pfSense, injection détectable par Suricata) et tests de charge (latence, débit). L'impossibilité de revenir en arrière en *Waterfall* rend cette phase critique pour la suite du projet.

- **Objectif du Jalon** : certifier que l'infrastructure satisfait toutes les exigences de sécurité du CCF.
- **Livrable exigé** : rapport de tests complet (unitaires, intégration, pénétration, performance).
- **Critères d'acceptation techniques** : taux de détection Suricata au-dessus du seuil CCF ; latence VPN inférieure à 10 ms ; zéro flux non autorisé ; rapport Ollama généré correctement.
- **Rôle de garde-fou** : dernier verrou qualité avant production ; un échec impose un retour ciblé en Phase 4 avec re-validation obligatoire.

Étape 6 — Déploiement sur Site et Transfert de Compétences (J6)

La dernière phase fait passer la maquette à la production réelle : migration des configurations validées et mise en service supervisée.

- **Objectif du Jalon** : certifier le fonctionnement opérationnel en production et l'autonomie de la PME, puis clore officiellement le projet.

- **Livrable exigé** : infrastructure en production documentée, PV de recette client signé.
- **Critères d'acceptation techniques** : fonctionnement nominal pendant 48 heures ; autonomie sur les opérations courantes.
- **Rôle de garde-fou** : conditionne la clôture du projet ; l'absence de signature du PV maintient la responsabilité de l'équipe sur les correctifs.

Ce découpage en six étapes illustre une vérité de l'approche *Waterfall* : la qualité finale est le produit de la discipline exercée à chaque clôture. En cybersécurité, où une configuration erronée expose l'ensemble du SI, cette discipline séquentielle est la condition de la fiabilité opérationnelle.

Diagramme de Flux Séquentiel

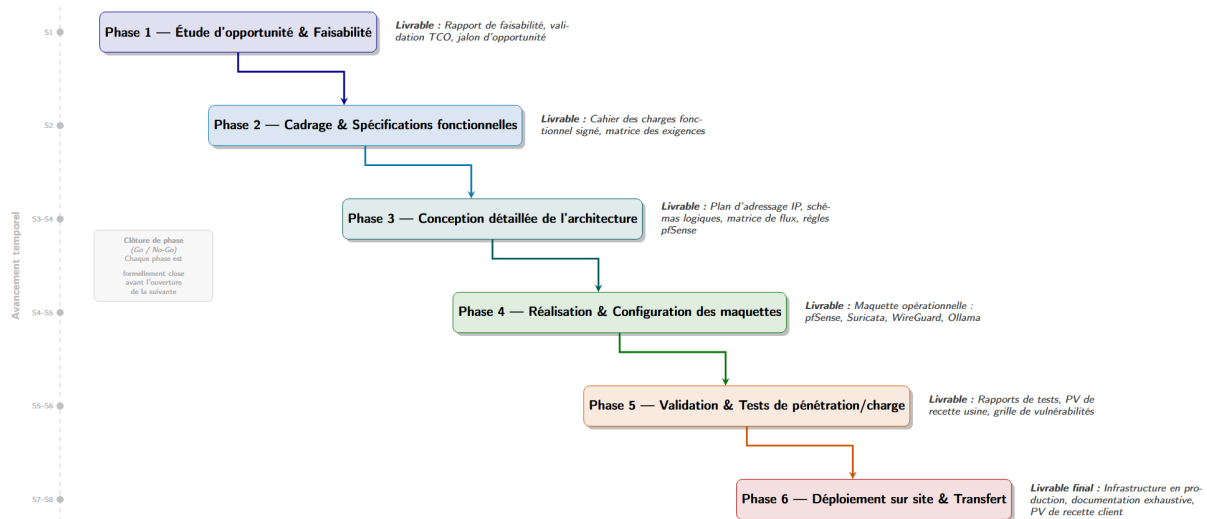


FIGURE 2.1 – Diagramme en cascade (Waterfall) des six phases séquentielles du projet OSSI avec jalons et livrables associés.

Chapitre 3

Application et Modélisation Complète du Cycle en V

3.1 Côté Gauche du V : Phases de Conception

Analyse des Besoins

Trois besoins métier identifiés par entretiens avec le dirigeant :

- **B1 — Accès distant sécurisé** : authentification forte, chiffrement de bout en bout, sans dégradation d’usage pour les commerciaux nomades.
- **B2 — Anti-ransomware** : confinement d’un poste compromis avant propagation latérale (segmentation + inspection comportementale, pas seulement périmétrique).
- **B3 — Restitution décisionnelle** : synthèse périodique vulgarisée, sans lecture de journaux bruts par le dirigeant.

TABLE 3.1 – Synthèse du recueil des besoins – Projet OSSI

Besoin exprimé	Reformulation analytique	Acteur concerné
Accès distant sécurisé	Authentification forte + chiffrement de bout en bout du tunnel commercial	Commerciaux nomades
Anti-ransomware	Détection comportementale + segmentation pour limiter la propagation latérale	Dirigeant PME
Rapports clairs	Restitution vulgarisée et périodique de l’état de sécurité	Dirigeant PME

3.1.1 Spécifications Fonctionnelles

Priorisation MoSCoW (imposée par le jalon J2) :

TABLE 3.2 – Spécifications fonctionnelles selon la méthode MoSCoW

Priorité	Exigence fonctionnelle	Besoin source
Must	MFA obligatoire sur les tunnels WireGuard avant établissement de session	Accès distant sécurisé
Must	Blocage automatique des flux malveillants (signatures Suricata, IDS/IPS actif)	Anti-ransomware
Must	Synthèses PDF vulgarisées générées par Ollama, fréquence hebdomadaire min.	Rapports clairs
Should	Tableau de bord ntopng temps réel (bande passante, flux suspects)	Anti-ransomware
Should	Journalisation centralisée des connexions VPN, horodatée	Accès distant sécurisé
Could	Alerte push email sur signature critique Suricata	Anti-ransomware
Could	Gabarit de rapport Ollama personnalisable	Rapports clairs
Won't	Portail web d'auto-administration des règles pare-feu	—

Chaque *Must have* est un critère de test bloquant en branche montante ; les *Won't have* verrouillent le périmètre (pas de surface d'attaque non budgétée).

Spécifications Techniques

TABLE 3.3 – Synthèse des choix techniques retenus

Composant	Choix retenu	Justification
Plateforme pare-feu	x86 reconditionné, pfSense CE (8 Go RAM, quad-cœur)	Coût maîtrisé, communauté active
Cartes réseau	2× Intel double port (I350)	Pilotes FreeBSD stables, 4 interfaces, segmentation physique
IDS/IPS	Suricata inline + règles Emerging Threats Open	Gratuit, maintenance communautaire
VPN nomade	WireGuard + MFA (TOTP)	Légèreté, performance
VPN site-à-site	IPSec (IKEv2, AES-256)	Standard interopérable, conforme ANSSI

Conception Détaillée

Quatre zones de confiance, interconnectées exclusivement via pfSense : **LAN** (postes, dirigeant), **DMZ** (serveurs exposés), **VPN Pool** (clients WireGuard), **Management** (pfSense, Suricata, ntopng, Ollama — isolé du LAN).

TABLE 3.4 – Plan d’adressage IP par segment

Segment	Plage d’adressage	VLAN ID	Fonction
LAN	192.168.10.0/24	VLAN 10	Postes bureautiques, dirigeant
DMZ	192.168.20.0/24	VLAN 20	Serveurs exposés (ERP, mail)
VPN Pool	10.10.30.0/24	VLAN 30	Clients WireGuard nomades
Management	192.168.99.0/28	VLAN 99	pfSense, Suricata, ntopng, Ollama

TABLE 3.5 – Matrice des règles de filtrage pfSense (extrait initial)

ID	Sens	Source	Destination	Action	Justification
R01	In	WAN (Any)	WireGuard (UDP/51820)	Allow	Point d’entrée unique VPN nomade
R02	In	WAN (Any)	Toutes inter-faces	Deny	Deny by default
R03	In	VPN Pool	LAN (ports applicatifs)	Allow (post-MFA)	Accès conditionné MFA
R04	In	VPN Pool	DMZ	Deny	Cloisonnement commercial/DMZ
R05	Out	LAN	DMZ	Allow (IDS)	Flux internes inspectés
R06	Out	LAN	WAN	Allow (IDS)	Navigation, MAJ inspectées
R07	In/Out	LAN	Management	Deny	Isolation admin stricte
R08	Out	DMZ	WAN	Deny (sauf exceptions)	Limite exfiltration / C2

R02 = deny by default. R08 limite l’exfiltration en cas de serveur DMZ compromis (anti-C2). Traçabilité ascendante : règle pfSense → exigence MoSCoW → besoin métier, condition de la branche montante.

Topologie Réseau Cible (Physique et Logique)

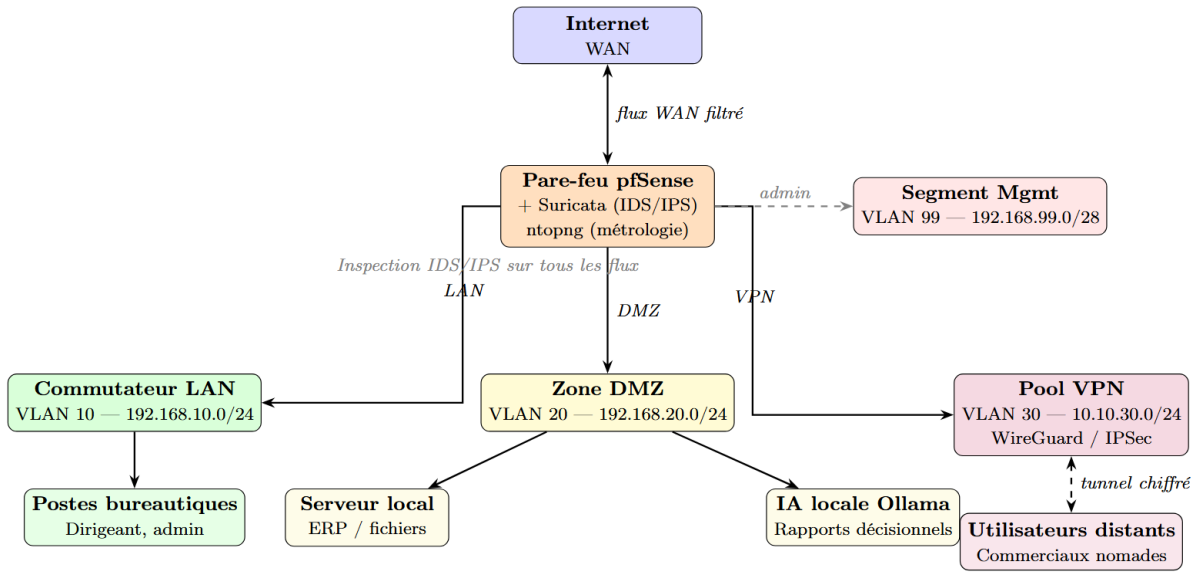


FIGURE 3.1 – Architecture réseau et de sécurité de la solution OSSI

3.2 Base du V : Phase de Réalisation et Organisation Opérationnelle

1. Organisation et Environnement de Maquettage

Équipe de 5 ingénieurs (RACI, Partie IV) :

- **Binôme Infra & Sécurité périmétrique** : pfSense, Suricata inline, WireGuard/IPSec. Cœur critique conditionnant J4 puis la Phase 5.
- **Binôme Supervision** : ntopng + Ollama, démarré dès interfaces inter-systèmes figées en J3.
- **Chef de Projet Technique / RQ** : coordination, journal de déploiement, dépôt Git, point de contact COPIL.

Maquettage sous **Proxmox VE** (KVM), retenu pour : absence de coût licence, compatibilité native pfSense/Suricata/ntopng/Ollama, snapshots (retour instantané en cas d'erreur). Parc de VM : pfSense (2 vCPU/4 Go, 4 if. OVS), Suricata/ntopng (2 vCPU/4 Go), Ollama (4 vCPU/8 Go, GGUF quantifié sans GPU), 2 VM clientes (LAN, WireGuard distant). Topologie exportée en config Git pour reproductibilité.

2. Méthodologie de Configuration Séquentielle

1. **pfSense** : assignation interfaces selon plan d'adressage, DHCP LAN, deny all (R02), durcissement (SSH off, WebGUI restreinte Management, anti-spoofing, logs vers ntopng). Versionné Git (shell, exports XML).
2. **Suricata** : paquet pfSense, IPS inline sur WAN, règles ET Open par catégories Phase 3 (hors faux positifs documentés), tuning itératif (buffers, threads) selon seuils latence J5.
3. **VPN** : WireGuard via paquet officiel, clés générées par script Python versionné ; IPSec site-à-site en parallèle (IKEv2/AES-256, conforme ANSSI).
4. **Ollama** : script Bash (binaire, modèle GGUF, service systemd) + script Python (extraction EVE-JSON, prompt, appel API, rendu PDF). Revue chef de projet avant intégration.

3. Dépôt Git et Journalisation

Dépôt Git privé (GitLab auto-géré sous Proxmox, souveraineté numérique — aucune clé/règle sur cloud tiers). Arborescence : /pfsense, /suricata, /vpn, /ollama, /docs. Merge request validée par le chef de projet avant **main**. Journal de déploiement (Markdown) : écarts schémas J3 / implémentation, justification, traçabilité anomalie → configuration source (Phase 5).

TABLE 3.6 – Allocation des composants logiciels et responsabilités de déploiement

Composant	VM Proxmox	Responsable	Livrable de configuration
pfSense CE	VM-01 (2 vCPU/4 Go)	Binôme Infra	Export XML + script de validation
Suricata IPS	VM-01 (intégré)	Binôme Infra	Règles ET + paramètres tuning
WireGuard / IPsec	VM-01 (intégré)	Binôme Infra	Script Python génération de clés
ntopng	VM-02 (2 vCPU/4 Go)	Binôme Supervision	Config ntopng + flux Suricata
Ollama (LLM local)	VM-03 (4 vCPU/8 Go)	Binôme Supervision	Script Bash déploiement + pipeline Python
Documentation & Git	GitLab (VM-04)	Chef de Projet	Dépôt structuré + journal de déploiement

3.3 Côté Droit du V : Stratégie de Tests et Validation

Quatre niveaux séquentiels, en miroir des quatre strates de conception. Tout échec impose un retour ciblé en réalisation (journal Git) avant reprise du niveau.

TABLE 3.7 – Matrice de correspondance biunivoque Cycle en V — Projet OSSl

Niv.	Conception (gauche)	Niv.	Validation (droite)	Jalon
C1	Besoins métier (B1–B3)	V4	Recette utilisateur devant le dirigeant	J6
C2	Spécifications MoSCoW (MFA, IPS, rapports)	V3	Validation fonctionnelle (Must have)	J5
C3	Spécifications techniques (pfSense, Suricata, WireGuard, ntopng)	V2	Tests d'intégration	J4–J5
C4	Conception détaillée (VLAN, R01–R08)	V1	Tests unitaires	J4

V1 — Tests Unitaires (TU)

TABLE 3.8 – Tests unitaires

ID	Composant	Objectif du Test	Résultat Attendu
TU-01	pfSense	Démarrage à froid, <code>pfctl -s info</code>	Enabled en <45s, 4 interfaces assignées (Tab. 3.4), 0 erreur CRITICAL (R02 actif dès l'init)
TU-02	Suricata	Chargement des signatures ET Open au démarrage	≥85% des signatures chargées sans erreur ; <code>ruleset-reload-nonblocking</code> = OK en <30s
TU-03	WireGuard	Disponibilité de l'interface <code>wg0</code> (UDP/51820)	<code>wg show</code> retourne clé + pairs ; 0 HANDSHAKE_FAILED
TU-04	Ollama	Démarrage service + disponibilité modèle	<code>/api/tags</code> répond <10s (statut <code>loaded</code>) ; génération 50→100 tokens <60s, hors-ligne
TU-05	ntopng	Accessibilité interface web (TCP/3000)	Dashboard accessible depuis VLAN 99 ; accès depuis VLAN 10 rejeté et journalisé (R07)

Échec = fiche de non-conformité (`/tests/TU/`) ; campagne rejouée intégralement après correctif avant passage en V2.

V2 — Tests d'Intégration (TI)

TABLE 3.9 – Tests d'intégration

ID	Composant	Objectif du Test	Résultat Attendu
TI-01	Suricata → ntopng	Transfert des alertes EVE-JSON (injection signature ET/scan)	Alerte visible sur ntopng <30s ; 100 alertes consécutives transmises sans perte
TI-02	Python → Ollama API	Envoi de 50 alertes EVE-JSON via <code>/api/generate</code>	Synthèse structurée reçue <120s, JSON valide, parsable sans exception
TI-03	pfSense → ntopng	Propagation des métriques WAN (trafic <code>iperf3</code> 50 Mbps)	Débit ntopng cohérent avec <code>iperf3</code> (±10%) en <60s
TI-04	WireGuard MFA	Connexion avec/sans jeton TOTP	Sans TOTP : rejet + log IP source. Avec TOTP : tunnel <5s, adresse attribuée dans 10.10.30.0/24

Échec TI = incohérence d'interface (format log, port, délai); *change request* si écart aux spécifications J3.

V3 — Validation Fonctionnelle (VF)

TABLE 3.10 – Validation fonctionnelle (exigences Must have)

ID	Composant	Objectif du Test	Résultat Attendu
VF-01	Accès distant (F1)	Connexion commercial externe : MFA TOTP puis accès LAN	Tunnel <10s; accès LAN autorisé; accès DMZ bloqué (R04, log pfSense); latence <10ms
VF-02	Anti-ransomware (F2)	Simulation scan ports + SMB non autorisé + DNS ET/malware	3/3 alertes Suricata générées; flux bloqué (IPS); log ntopng; 0 propagation DMZ (R05, R08)
VF-03	Rapport Ollama (F3)	Pipeline déclenché sur le lot d'alertes VF-02	Rapport PDF intelligible sans terme technique non défini, validé par le chef de projet (rôle dirigeant)

V4 — Recette Utilisateur

Recette en présence du dirigeant et du chef de projet, formant la condition de signature du PV de livraison (J6). Quatre actes consécutifs :

TABLE 3.11 – Scénario de recette utilisateur

ID	Acte	Objectif du Test	Résultat Attendu
RU-01	Connexion commercial (B1)	Connexion WireGuard depuis l'extérieur, TOTP unique	Flux VPN visible en temps réel sur ntopng, sans config manuelle
RU-02	Intrusion simulée (B2)	Scan de ports externe sur WAN	Alerte Suricata visible en direct; logs pfSense confirmant 0 accès interne
RU-03	Rapport décisionnel (F3)	Lecture guidée du rapport Ollama post-intrusion	Dirigeant déclare pouvoir décider sur le seul rapport, sans complément
RU-04	Autonomie MCO	Exécution sans aide : MAJ signatures, ajout règle pfSense, lecture rapport	3 opérations réalisées en autonomie; PME indépendante de l'équipe OSSI

À l'issue des 4 actes, signature du PV de recette par le dirigeant (statut Validé/Réservé/Rejeté par exigence MoSCoW, délai de levée des réserves le cas échéant). Toute réserve bloquante maintient le projet en déploiement jusqu'à correctif.

CONCEPTION (Branche descendante)

VALIDATION (Branche montante)

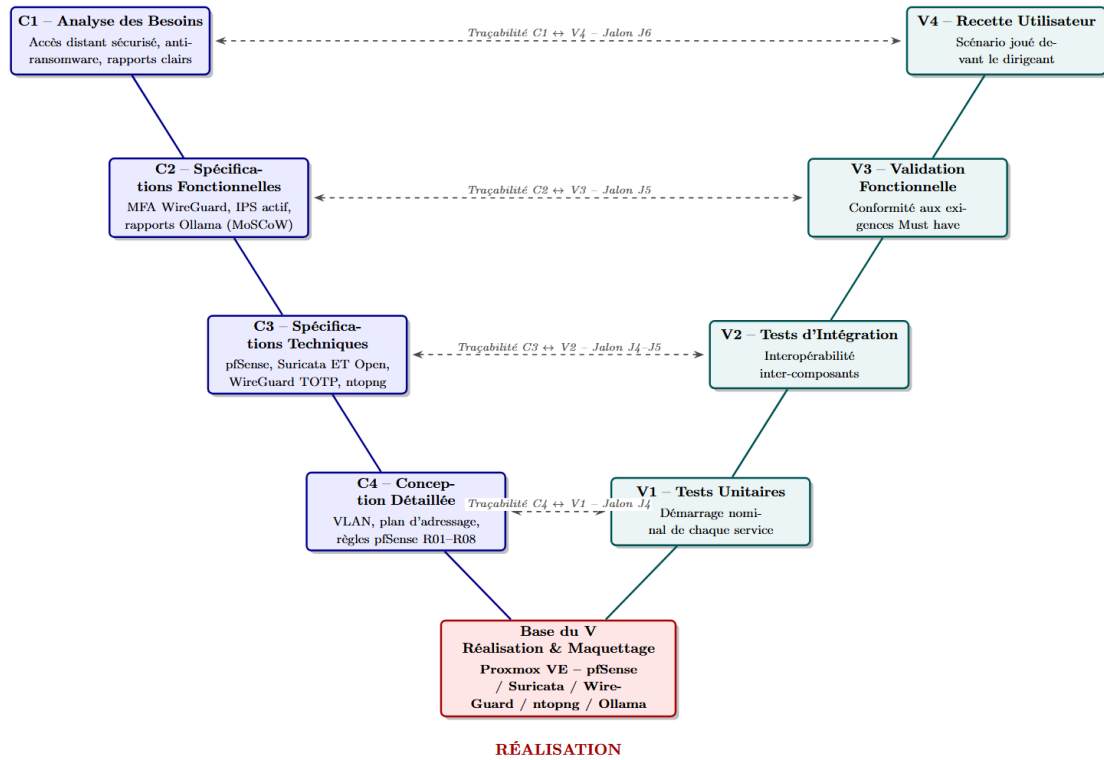


FIGURE 3.2 – Modèle en V complet et traçabilité des tests du projet OSS1

Chapitre 4

Gouvernance, Risques et Pilotage Qualité

4.1 Gouvernance du Projet OSSII

a) Direction de Projet

Direction collégiale assurée par les 5 ingénieurs : chaque expert décide sur son périmètre, le CP coordonne, arbitre en premier niveau et reste interface unique avec le COPIL. Périmètre, budget et calendrier ne sont jamais modifiables par la seule direction de projet. Principe : la direction **exécute et propose**, le COPIL **décide et valide**.

b) COPIL

Deux membres : dirigeant PME, CP. Réunions aux jalons décisionnels (J1–J6) uniquement, chacune adossée à un livrable formel et concluant sur **Go / Go conditionnel / No-Go**. Instance d'arbitrage de dernier recours pour tout changement de périmètre, budget ou calendrier.

c) Gestion des Changements

Procédure en 4 étapes : (1) formalisation – fiche de demande de changement (FDC) versionnée dans /governance/change-requests/ ; (2) chiffrage d'impact Coûts–Délais–Qualité ; (3) arbitrage COPIL – acceptation, rejet ou report ; (4) mise à jour CCF/budget/chronogramme et traçabilité Git.

Cas d'usage : demande d'intégration d'un serveur Active Directory.

TABLE 4.1 – Analyse d'impact – Intégration AD

Critère	Impact
Coûts	+1 400 € (licence, intégration LDAP/pfSense, GPO) → TCO >8 200 €, hors budget J1 (6 875 €)
Délais	+1,5 séance, non absorbable sans empiéter sur la Phase 5 (goulot identifié)
Qualité	Surface d'attaque accrue (AD cible classique des ransomwares), revue d'architecture complète requise, traçabilité R01–R08 remise en cause

Décision COPIL : **rejet motivé + report** en recommandation d'évolution hors périmètre contractuel. Garde-fou anti-*scope creep* sans rupture de confiance client.

4.2 Répartition des Rôles et Responsabilités

a) Dimensionnement

5 ingénieurs = optimum face aux 4 briques techniques (pare-feu, IDS/IPS, VPN, IA) sur 8 séances : une responsabilité principale par ingénieur + une coordination transversale.

b) Rôles

- **CP / Gouvernance** : coordination, journal Git, change management, interface COPIL. Sans responsabilité technique directe → objectivité d'arbitrage.
- **Expert pfSense** : install, durcissement, VLAN, règles R01–R08. Rôle individuel (criticité du socle).
- **Expert Suricata** : déploiement IPS, tuning, signatures ET Open. Distinct du filtrage périmétrique.
- **Intégrateur IA (Ollama)** : pipeline EVE-JSON, rapports décisionnels. Parallélisable dès interfaces de log figées (J3).
- **RAQ** : stratégie de tests, registre, traçabilité exigences/critères. Indépendant des rôles de réalisation (anti-biais de confirmation).

TABLE 4.2 – Matrice RACI – Projet OSSI

Activité	CP	pfSense	Suricata	IA	RAQ
Cadrage	R/A	C	C	C	C
Config. pfSense	A	R	C	I	I
Déploiement Suri- cata	A	C	R	I	I
Intégration API Ol- lama	A	I	C	R	I
Plan de tests	A	C	C	C	R
Recette utilisateur (J6)	A	C	C	C	R

CP = **A** systématique (sauf cadrage, où il est aussi R). RAQ jamais **R** sur la réalisation : indépendance du contrôle.

4.3 Analyse et Registre des Risques

Cotation Probabilité × Impact (1–5). Seuil d'escalade COPIL : criticité ≥ 12 .

TABLE 4.3 – Registre des risques – Projet OSSI

ID	Catég.	Risque	P	I	C	Contingence
R1	IA	Hallucination Ollama (menace/poste erroné)	3	4	12	Prompt restreint aux alertes fournies ; relecture binôme avant diffusion ; VF-03 bloquant ; repli gabarit structuré si récidive
R2	Réseau	Latence/débit dégradés par inspection inline Suricata	3	3	9	Tuning buffers/threads ; désactivation signatures faible valeur ; repli IDS passif si seuil VF-01 (<10ms) non tenable
R3	Planning	Dépassement des 8 séances (Phase 5)	4	4	16	Priorisation MoSCoW (Should/Could sacrifiés avant Must) ; point J3 ; replanification si écart >0,5 séance
R4	RH	Indisponibilité d'un expert R unique	2	5	10	Doc continue Git (XML, scripts, journal) ; polyvalence de secours CP ; 0 connaissance non versionnée

R3 (criticité 16) : seul risque au-dessus du seuil, traité comme point fixe à chaque jalon COPIL.

4.4 Critères de Validation des Livrables

TABLE 4.4 – Matrice d'assurance qualité – Projet OSSI

Livrable	Critère	Vérification	Resp.
Dépôt Git	0 secret en clair (clés, jetons) dans l'historique	Secret avant merge main	RAQ
Règles pfSense	Chaque règle documentée et rattachée à une exigence MoSCoW	Revue matrice de correspondance	CP+RAQ
Scripts Python/Bash	Code commenté, nommage normalisé, erreurs gérées	Revue de code avant main	CP
Rapports Ollama	0 jargon non défini, lisible non-spécialiste	Test qualitatif VF-03	RAQ
Guide MCO	Conforme à la config réellement déployée	Confrontation journal Git vs guide	RAQ
Registre de tests	100% des Must couverts, statut tracé	Audit de couverture	RAQ

Livrable *clos* seulement si tous ses critères sont satisfaits ; sinon statut *Réservé* en Git.

4.5 Indicateurs de Suivi (KPIs)

TABLE 4.5 – KPI projet – COPIL

Indicateur	Calcul	Cible	Fréq.
Écart budgétaire	(Dépenses – Prévu) / 6 875 €	$\leq 5\%$	Par jalon
Avancement calendaire	Séances consommées / 8 vs jalon	$\leq 0,5$ séance d'écart	Par séance
Demandes de changement	FDC déposées/acceptées/rejetées	0 hors report	Par jalon
Couverture existences Must	% Must testés (registre)	100% avant J6	J4–J6

TABLE 4.6 – KPI produit – COPIL

Indicateur	Calcul	Cible	Fréq.
Chargement signatures Suricata	% règles ET chargées sans erreur	$\geq 85\%$	J4, hebdo MCO
Faux positifs Suricata	Alertes requalifiées / total	$\leq 10\%$	J5, mensuel MCO
Temps de réponse Ollama	Délai déclenchement → PDF	$< 120s/50$ alertes	Par génération
Latence VPN homemade	Ping bout-en-bout post-tunnel	$< 10ms$	J5, trim. MCO
Disponibilité services critiques	Uptime pfSense/Suricata/WireGuard	$\geq 99\%$	J4–J6

Tout écart hors cible déclenche soit une action corrective directe (direction de projet), soit une FDC si dépassement de périmètre/budget/calendrier (J2).

Chapitre 5

Analyse Critique et Réflexion Managériale

5.1 Analyse Critique du Cycle en V dans le Contexte OSSI

Le choix d'un modèle prédictif en Cycle en V pour le projet OSSI s'est avéré particulièrement robuste pour la mise en place du socle d'infrastructure réseau et de sécurité. Dans un contexte de cybersécurité pour PME, la tolérance à l'erreur est nulle : une mauvaise configuration de pare-feu ou une DMZ perméable peut paralyser l'activité commerciale ou exposer des données hautement sensibles. Le Cycle en V garantit une traçabilité ascendante stricte, assurant que chaque exigence technique (étanchéité des VLANs, authentification MFA sur WireGuard) soit formellement validée par un test d'intégration ou fonctionnel dédié (de V1 à V4). La politique des jalons (J1 à J6) a agi comme un garde-fou managérial indispensable pour maîtriser le budget serré de 6 875 € et éviter le *scope creep*.

Cependant, cette rigidité séquentielle a révélé ses limites lors de l'intégration de la brique d'Intelligence Artificielle locale (Ollama). Le développement du script Python de traitement des logs et la gestion des hallucinations de l'IA ont nécessité de nombreuses itérations empiriques (*prompt engineering*), un processus organique difficilement compatible avec les phases figées du modèle cascade. De plus, la découverte tardive lors de la phase d'intégration (V2) des goulots d'étranglement CPU/RAM sur Proxmox VE, causés par l'inspection *inline* de Suricata, illustre l'effet tunnel inhérent à cette méthodologie.

Synthèse des Forces et Faiblesses Méthodologiques

Le tableau 5.1 synthétise l'impact systémique de l'approche Cycle en V sur la réalisation de l'infrastructure OSSI.

Forces du Modèle (Socle Réseau)	Faiblesses du Modèle (Module IA)
Sécurité by Design : Correspondance stricte et biunivoque entre spécifications et tests (V1-V4).	Incompatibilité avec l'IA : Processus itératif d'optimisation d'Ollama bridé par la rigidité des phases.
Gouvernance Maîtrisée : Jalons Go/No-Go clairs empêchant les dérives budgétaires et techniques.	Effet Tunnel : Risque de découverte tardive des conflits de performance (Suricata vs ressources Proxmox).
Rigueur Documentaire : Traçabilité totale, idéale pour l'auditabilité et le transfert au Responsable Assurance Qualité.	Lourdeur Opérationnelle : Surcharge administrative peu adaptée au format court de 8 séances de travail.

TABLE 5.1 – Analyse comparative des impacts méthodologiques sur le projet OSSI

5.2 Comparaison avec une Approche Agile ou Hybride

Une gestion de projet 100 % Agile (type Scrum) aurait été contre-productive pour la partie infrastructure : planifier le déploiement d'un cœur de réseau par incréments de deux semaines sans vision d'architecture globale expose l'entreprise à des failles architecturales majeures. À l'inverse, l'approche prédictive pure a ralenti l'innovation logicielle liée à l'exploitation de l'IA.

Pour pallier ce paradoxe, un framework de gestion de projet hybride est proposé. Ce modèle applique une approche prédictive rigoureuse (Waterfall / Cycle en V) pour sécuriser le socle immuable de l'infrastructure (routage, filtrage pfSense, isolation réseau). En parallèle, la couche applicative innovante (script de parsing et requêtage de l'API Ollama) est développée selon un cycle itératif Agile, structuré en sprints courts d'une séance. Les incréments de l'IA s'intègrent de manière continue dans la maquette virtuelle Proxmox VE, permettant d'ajuster dynamiquement le modèle de langage sans jamais compromettre la stabilité et la disponibilité du réseau de production de la PME.

Framework de Gestion de Projet Hybride Proposé

Le schéma suivant illustre l'interfaçage et les points de synchronisation entre la structure rigide du Cycle en V (branche descendante et montante) et les boucles itératives des sprints Agiles dédiés au module Ollama.

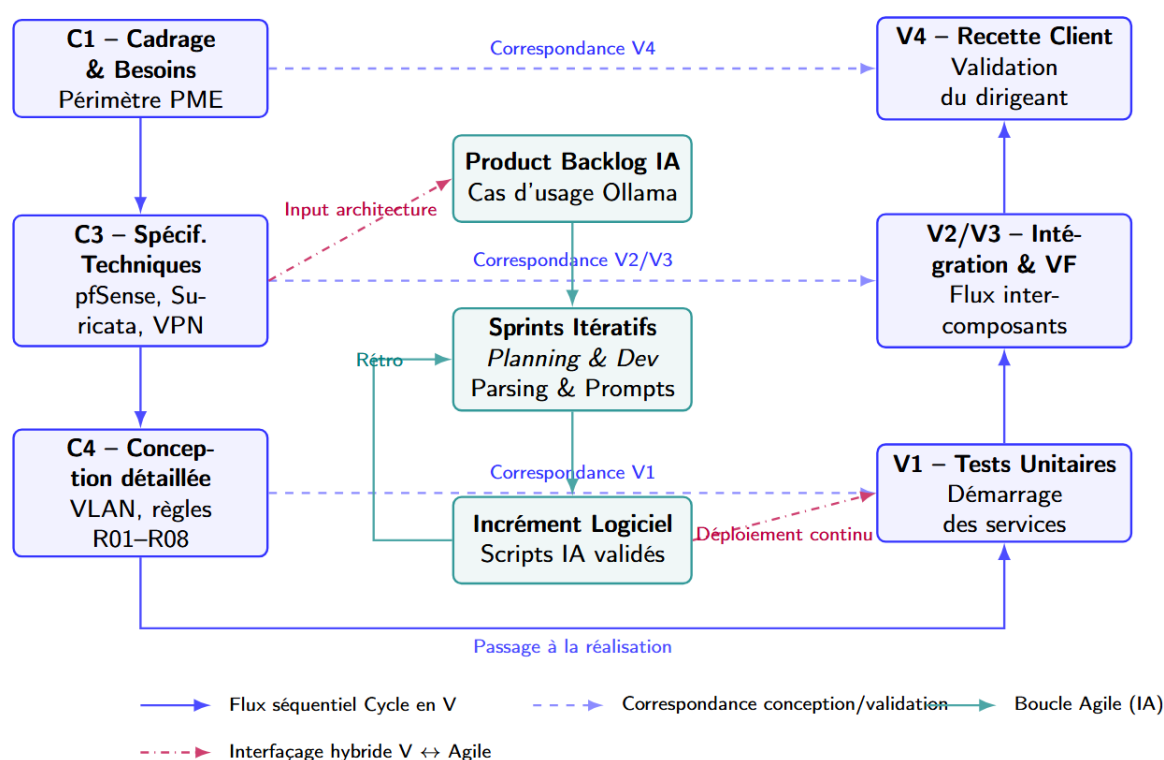


FIGURE 5.1 – Modèle d'interfaçage des Sprints Agiles avec le Cycle en V

5.3 Conclusion Réflexive et Apports pour la Formation d'Ingénieur

Cette simulation de gestion de projet Mastercamp met en évidence qu'un projet d'ingénierie ne se résume pas à l'implémentation de solutions techniques, aussi performantes soient-elles. Le déploiement d'outils Open Source (pfSense, Suricata, Ollama) au service d'une PME exige un cadre managérial et méthodologique strict pour garantir la viabilité économique (respect de l'enveloppe de 6 875 €) et la qualité des livrables.

Sur le plan organisationnel, l'utilisation couplée de la matrice RACI et de la politique des jalons a démontré l'importance de la clarté des rôles pour optimiser l'efficacité d'une équipe de 5 ingénieurs sous contrainte de temps (8 séances). Sur le plan technique, la confrontation avec les limites de performance du matériel reconditionné a développé notre capacité d'arbitrage face aux compromis réels de l'industrie (sécurité vs performance). Cette expérience forge la posture de l'ingénieur de demain : un professionnel capable d'articuler une expertise cybersécurité de pointe avec une vision stratégique et financière globale, tout en intégrant les enjeux de souveraineté numérique et de sobriété technologique.